

Clase 193 — Detección de C2 y beaconing

Parte: **8 — Blue Team, detección y SOC** · Fuente: *Applied Network Security Monitoring* — Sanders y Smith · *MITRE ATT&CK* (Command and Control) 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

🎯 Objetivo

Detectar canales de mando y control (C2) y su patrón de beaconing: las llamadas periódicas que un implante hace a su servidor. Aprenderás a reconocer regularidad temporal, jitter, dominios y fingerprints de frameworks como Cobalt Strike, y a cazar C2 sobre HTTP/S, DNS y protocolos comunes usando telemetría de red y endpoint.

⚠️ **Ética:** cualquier despliegue de C2 (p. ej. un teamserver de laboratorio) para generar telemetría se hace exclusivamente en tu entorno propio y aislado. El fin es construir detección defensiva.

📖 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Explicar** cómo funciona un canal C2 y qué es el beaconing (intervalo + jitter).
- 2. **Detectar** periodicidad de conexiones con análisis estadístico.
- 3. **Identificar** C2 sobre HTTP/S, DNS y dominios de malleable profiles.
- 4. **Usar** JA3/JA3S y fingerprints para detectar frameworks conocidos.
- 5. **Escribir** detecciones de C2 mapeadas a ATT&CK Command and Control.

📖 Temas

#	Tema	Por qué importa
1	Anatomía de un canal C2	Entender qué detectar
2	Beaconing: intervalo y jitter	La huella temporal del implante
3	C2 sobre HTTP/S	El canal más común
4	C2 sobre DNS	Evasión mediante resolución
5	Malleable C2 y evasión	Cómo se camuflan los frameworks
6	JA3/JA3S y fingerprints	Identificar herramientas
7	Análisis estadístico (RITA)	Detectar regularidad automáticamente
8	Correlación con endpoint	Atar el canal al proceso

Definiciones y características

- **C2 (Command and Control):** infraestructura desde la que el atacante controla los hosts comprometidos. Característica: prioriza sigilo y persistencia del canal.
- **Beacon:** implante que "llama a casa" periódicamente esperando órdenes. Característica: conexiones regulares de bajo volumen.
- **Jitter:** variación aleatoria del intervalo de beacon para evitar detección. Característica: dispersa la periodicidad, pero rara vez la elimina del todo.
- **Malleable C2:** perfiles que hacen que el tráfico imite servicios legítimos (jQuery, CDN). Característica: engaña inspecciones superficiales.
- **JA3/JA3S:** fingerprint del handshake TLS. Característica: algunos frameworks tienen JA3 característicos, detectables aun con cifrado.
- **DNS C2:** órdenes/datos codificados en consultas y respuestas DNS. Característica: alta cadencia de subdominios y registros TXT inusuales.
- **Domain fronting:** ocultar el destino real tras un dominio de CDN legítimo. Característica: SNI benigno con Host header distinto.

Herramientas y preparación

En laboratorio aislado:

- **Zeek** (conn/dns/ssl.log) y **Suricata** como fuentes de red.
- **RITA** para análisis de beaconing y DNS tunneling sobre logs de Zeek.
- Un **framework C2 de laboratorio** para generar tráfico de prueba (p. ej. un teamserver propio o un simulador de beacon benigno).
- Tu SIEM y la telemetría Sysmon (Event 3 y 22) para correlación.

Nunca dirijas C2 real contra sistemas ajenos; todo el tráfico se genera y captura en tu red de pruebas.

Laboratorio guiado — Caza el latido del beacon

1. **Genera un beacon.** En laboratorio, configura un implante benigno que se conecte a un servidor propio cada 60 s con un jitter del 20%.
2. **Captura con Zeek.** Deja correr el tráfico varios minutos para acumular suficientes conexiones en conn.log.
3. **Analiza periodicidad.** Con RITA, importa los logs y ejecuta el análisis de beaconing; observa el score y el intervalo estimado.
4. **Detección manual.** En el SIEM, agrupa conexiones por par (origen, destino) y calcula la desviación de los deltas de tiempo: baja varianza = beacon.
5. **Prueba C2 sobre DNS.** Configura el implante para usar DNS; detecta la alta cadencia de subdominios y respuestas TXT largas.
6. **Fingerprint TLS.** Extrae el JA3 del cliente y compáralo con listas de frameworks conocidos.
7. **Correlaciona con endpoint.** Enlaza la conexión periódica (Sysmon Event 3) con el proceso responsable y su árbol (clase 189).
8. **Escribe la detección.** Crea una regla que alerte ante conexiones de baja varianza temporal y bajo volumen sostenidas a un mismo destino.

Ejercicios

1. Explica cómo el jitter dificulta la detección y por qué no la impide.
2. Calcula la varianza de intervalos de una serie de conexiones y decide si es beacon.
3. Diseña una detección de C2 sobre DNS basada en cadencia y entropía.
4. Describe cómo JA3 detecta un framework aun con TLS.
5. Explica el domain fronting y cómo lo delatarían SNI vs Host header.
6. Correlaciona un beacon de red con el proceso de endpoint que lo genera.

Reto verificable

Detecta un beacon generado en tu laboratorio combinando análisis temporal (periodicidad) y correlación con el proceso de endpoint. **Criterio de aceptación:** identificas el par origen-destino del beacon con su intervalo aproximado y jitter, justificas la detección con datos estadísticos (baja varianza), y enlazas la conexión con el proceso concreto que la origina en el host.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Servicios legítimos marcan como beacon	Telemetría, updates y sync también son periódicos; añade allowlist
Jitter alto evade tu regla	Umbral de varianza rígido; usa análisis estadístico (RITA) más tolerante
No ves C2 sobre DNS	Falta logging DNS; captura con Zeek/Sysmon 22
JA3 no identifica nada	Framework con perfil malleable; combina con periodicidad y volumen
Falsos positivos de CDN	Malleable/domain fronting; correlaciona SNI vs Host y con endpoint

Preguntas frecuentes

 **Si el C2 usa jitter, ¿es indetectable?** No. El jitter dispersa el intervalo, pero un beacon sigue siendo mucho más regular que la navegación humana. El análisis estadístico sobre suficientes muestras lo revela.

 **¿Puedo detectar C2 cifrado?** Sí, por metadatos: periodicidad, volumen, JA3, dominios y correlación con el proceso. No necesitas descifrar para reconocer el patrón de un implante.

 **¿Beaconing siempre es malicioso?** No. Actualizaciones, telemetría y sincronización también "laten". Por eso se combina periodicidad con reputación de destino, volumen y contexto de endpoint antes de escalar.

Referencias

- MITRE ATT&CK, Command and Control — <https://attack.mitre.org/tactics/TA0011/>
- RITA — <https://github.com/activecm/rita>
- JA3 (Salesforce) — <https://github.com/salesforce/ja3>

- Sanders, C. y Smith, J. *Applied Network Security Monitoring*. Syngress.
- Active Countermeasures, "Detecting Beacons" (recursos formativos) — <https://www.activecountermeasures.com/>

Siguiente clase

Clase 194 - Deception: honeypots y honeytokens